NETWORKWALKS CYBERSECURITY PROGRAM · WEEK 02

PENETRATION TESTING REPORT

Footprinting & Network Scanning Phases

W2-PM-FINAL | CYBERSECURITY | NETWORKWALKS

Targets

networkwalks.com · 192.168.18.0/24 (own local network)

Prepared by	**Prince** · Cybersecurity trainee
Programme	Networkwalks Cybersecurity Program · Week 02
Report date	11 November 2026
Modules completed	**W2-PM1** · Footprinting with multiple Kali Linux tools **W2-PM5** · Network scanning with Zenmap
Client / target	1. Networkwalks (written permission secured) 2. My own local network
Permission secured?	**Yes** · for every system touched in this report
Phases covered	**Phase 1:** Reconnaissance & footprinting **Phase 2:** Scanning & network discovery **Phases 3–5:** In progress
Document status	Version 1.0 · Final · Educational lab report

7	11	0	8
tools used	observations logged	exploits attempted	live LAN hosts found

Observations only. This report documents reconnaissance and host discovery; no exploitation or vulnerability validation was performed.

Contents

1	Liability Disclaimer	Authorisation and responsible-use statement
2	Executive Summary	Headline results and overall exposure
3	Scope, Rules & Methodology	What was in scope and how the work was done
4	Tools Used	Eight tools and how each one touches the target
5	Phase 1: Footprinting & Reconnaissance	WHOIS, WhatWeb, Nslookup, Curl, Wafw00f, DNSRecon
6	Phase 2: Network Scanning with Zenmap	Ping scan, host inventory, MAC analysis, topology
7	Risk Analysis & Findings Register	11 rated observations and controls that worked
8	Recommendations	Prioritised remediation roadmap
9	Conclusion & Lessons Learned	What I learned and what comes next
A–D	Appendices	Command log, evidence index, ATT&CK mapping, glossary, references

1. Liability Disclaimer

Every activity in this report was performed only on systems that I own, or on systems for which I held written permission. The **networkwalks.com** domain is the designated lab target of the Networkwalks Cybersecurity Program, and **192.168.18.0/24** is my own local network.

This material is written for education and research. Please do not use anything in it to break the law. Unauthorised access to a computer system is a criminal offence in most countries, including under Nigeria's Cybercrimes (Prohibition, Prevention, etc.) Act 2015, even when no damage is done. Misuse can lead to criminal charges, heavy fines, loss of employment and a permanent record.

The instructor, the author and Networkwalks are not responsible for what anyone does with this knowledge. Every action you take is your own responsibility.

> **Authorisation statement**
>
> Systems tested: networkwalks.com (written permission) and my own local network (owner).
>
> Techniques used: WHOIS, DNS queries, one HTTP header request, technology and WAF fingerprinting, and a ping sweep. Nothing was exploited.

2. Executive Summary

This report covers two practical exercises from Week 2 of the Networkwalks Cybersecurity Program. In **W2-PM1** I footprinted the public domain **networkwalks.com** with six Kali Linux tools. In **W2-PM5** I used **Zenmap** to discover live hosts on my own network, **192.168.18.0/24**. Together they follow the opening moves of an attacker: gather public information first, then map what is alive on a network.

I did not exploit anything, guess passwords, fuzz inputs or port-scan a host. Every observation below comes straight from tool output, and each one is tied to a screenshot.

Headline results

- **The website's technology stack is easy to read.** Headers and page content disclose Apache, WordPress 7.1.4, WordPress Download Manager 3.3.76 and jQuery 3.7.1, and they point to the REST API at `/wp-json/`.
- **Several good controls are already in place.** HTTP redirects to HTTPS, the session cookie is `Secure` and `HttpOnly`, ModSecurity (SpiderLabs) protects the site, and the registrar has locked the domain against transfer, update and deletion.
- **DNS and email records reveal a little more than necessary.** The name servers advertise BIND 9.16.23-RH, SPF ends in a soft fail (`~all`) and DNSSEC is not enabled.
- **The local network has eight live devices.** One is a ZTE device at `192.168.18.1` (most likely the router), one is a Hikvision device, one comes from an IoT module vendor, and three use randomised MAC addresses that no vendor lookup could attribute.
- **Overall result:** 11 observations, made up of 0 critical, 0 high, 2 medium, 7 low and 2 informational. None of them is a confirmed vulnerability.

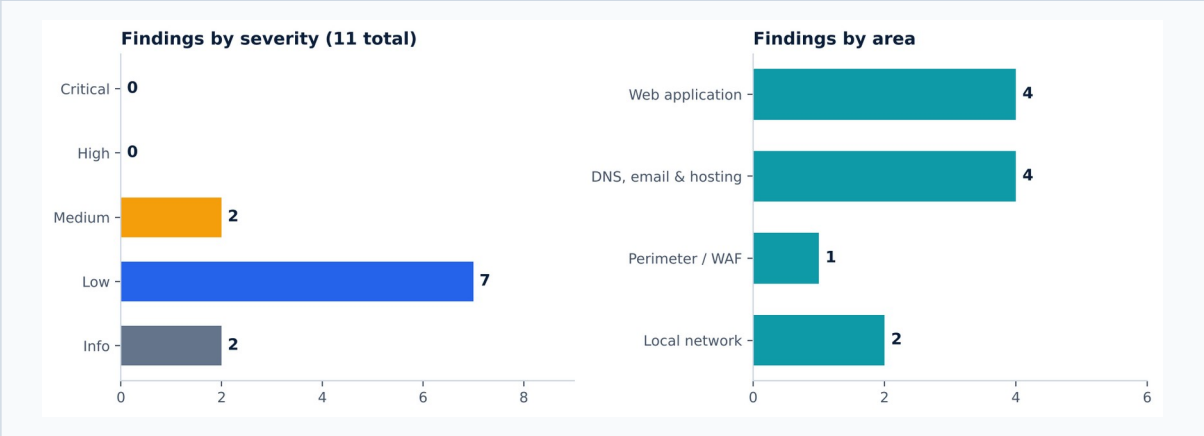


Figure 1. Findings by severity and by area (full register in Section 7).

> **Bottom line**
>
> The public footprint of networkwalks.com is typical for a WordPress site on shared hosting, and the perimeter controls that matter most are present. The three actions with the best return are: keep WordPress and the Download Manager plugin patched, add browser security headers, and move the camera and IoT devices onto a separate network segment at home.

3. Scope, Rules & Methodology

3.1 Scope

Target	What it is	Activity performed	Deliberately not done
`networkwalks.com` (192.232.216.135)	Public web domain, lab target of the programme	WHOIS and DNS lookups, one HTTP HEAD request, technology fingerprinting, WAF detection	Exploitation, login attempts, fuzzing, brute force, denial of service, port scanning
`192.168.18.0/24`	My own local network	Ping sweep (host discovery) with Zenmap / Nmap	Port and service scans, access to any device, traffic capture

3.2 Method

I followed the first two steps of the usual penetration-testing flow and kept the same routine for every tool, so each finding can be checked back to its evidence:

1. **Confirm scope and permission** before running anything.
2. **Collect public data first**: WHOIS and DNS answers come from registries and resolvers, not from the target's web server.
3. **Make light, direct requests**: one header request, WhatWeb, wafw00f and DNSRecon touch the target, so they were run once each.
4. **Map the local network** with a ping sweep and read the results (IP, MAC, vendor, latency).
5. **Record, rate and recommend**: every tool section has the exact command, the observed result, a screenshot, an attacker's view and a defender's takeaway.

3.3 Environment

Footprinting host	Kali Linux in an Oracle VirtualBox VM named "NETWORKWALKS LAB SETUP"
Scanning host	Windows PC running Zenmap with Nmap 7.993
Run date	11 November 2026 (tool timestamps are listed in Appendix A)

4. Tools Used

"Interaction" shows how directly each tool touches the target. Passive tools query public databases or a public resolver. The others send traffic to the target itself.

Tool	Purpose in this report	Interaction	Module
Kali Linux + Windows	Operating systems used for reconnaissance and for scanning	n/a	W2-PM1 / PM5
`whois`	Domain registration: registrar, dates, name servers, status locks	**Passive**	W2-PM1
`nslookup`	Resolve the domain name to its IP address through Google DNS	**Passive**	W2-PM1
`whatweb`	Fingerprint web technology: server, CMS, plugins, scripts, IP	**Active**	W2-PM1
`curl -I`	Read the HTTP response headers of the website	**Active**	W2-PM1
`wafw00f` v2.4.2	Detect whether a web application firewall is present	**Active**	W2-PM1
`dnsrecon`	Enumerate NS, SOA, MX, A, TXT/SPF and SRV records	**Semi-active**	W2-PM1
Zenmap (Nmap 7.993)	Ping-scan the subnet for live hosts, IPs, MACs and topology	**Active (own LAN)**	W2-PM5

5. Phase 1: Footprinting & Reconnaissance

The goal of Phase 1 is to learn as much as possible about **networkwalks.com** without breaking anything. I used six Kali tools, each one answering a different question: who owns the domain, what software runs the site, where it lives, what the server says about itself, what protects it, and how its DNS is set up.

5.1 WHOIS: who registered the domain?

```
$ whois networkwalks.com
```

Item	Observed value
Registrar	GoDaddy.com, LLC (IANA ID 146)
Created / updated / expires	2019-11-06 / 2025-11-12 / 2027-11-06
Name servers	`NS6135.HOSTGATOR.COM`, `NS6136.HOSTGATOR.COM`
Status locks	clientDeleteProhibited, clientRenewProhibited, clientTransferProhibited, clientUpdateProhibited
DNSSEC	unsigned
Abuse contact	abuse@godaddy.com · 480-624-2505

No registrant name, e-mail address or phone number appears in the captured output, so personal contact data is not exposed here.

Attacker's perspective	Defender's takeaway
The registrar and the DNS host are now known targets for phishing and support-desk social engineering. Domain age and the expiry date show how long the domain has been in use and when it comes up for renewal.	The four status locks make an unauthorised transfer or edit harder. Keep auto-renew on, protect the registrar account with MFA, and watch the expiry date.

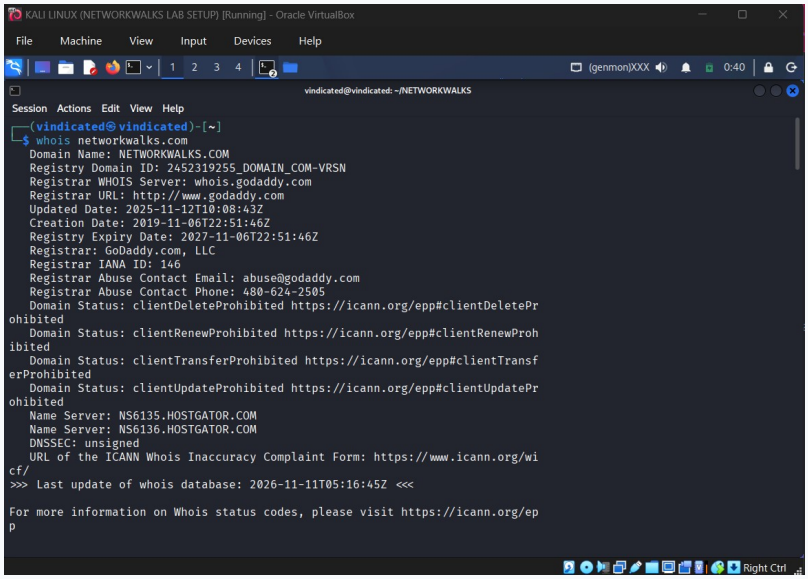


Figure 2. WHOIS output for networkwalks.com (Kali Linux terminal).

5.2 WhatWeb: what technology runs the site?

```
$ whatweb networkwalks.com
```

Item	Observed value
Redirect	`http://networkwalks.com` returns 301 Moved Permanently to `https://networkwalks.com/`
Web server	Apache
CMS	WordPress 7.1.4 (from the MetaGenerator tag)
Plugin	WordPress Download Manager 3.3.76
Scripts and services	jQuery 3.7.1, Google Tag Manager, Open Graph protocol, HTML5
Page title / contact	Networkwalks Academy · `info@networkwalks.com`
Cookie	`__wpdm_client` (HttpOnly)
IP / country	192.232.216.135 · United States
Other	Frame (iframe use) and a `Bootstrap[7.1.4]` match

The `Bootstrap[7.1.4]` result repeats the WordPress version number exactly, which makes me think it is a version-matching artefact of WhatWeb rather than a real Bootstrap release. I treat it as unverified.

Attacker's perspective	Defender's takeaway
Exact CMS and plugin versions can be looked up against public advisories. Plugins are historically where most WordPress compromises start, so the Download Manager version is the most useful detail here.	Patch quickly, remove unused plugins and turn on automatic security updates. Hiding the version tag helps a little but never replaces patching. I have not checked these versions against advisories, so none of this is a claim of vulnerability.

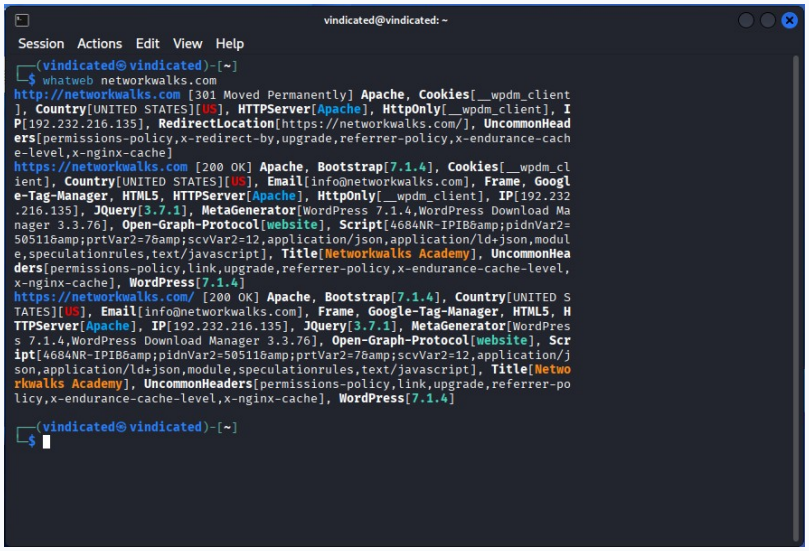


Figure 3. WhatWeb fingerprint of networkwalks.com.

5.3 Nslookup: where does the name point?

```
$ nslookup networkwalks.com
```

Item	Observed value
Resolver used	8.8.8.8 (Google Public DNS), port 53
Answer type	Non-authoritative
Resolved address	**192.232.216.135**

The same address appears in the WhatWeb output and in the DNSRecon A and MX records, so three separate tools agree on where the site lives.

Attacker's perspective	Defender's takeaway
The IP address is the starting point for any later port or service scan (with permission) and for finding other sites on the same shared host.	A shared-hosting IP cannot be hidden easily. Rely on patching and the WAF instead of on obscurity.



Figure 4. Nslookup resolving networkwalks.com through 8.8.8.8.

5.4 Curl: what do the HTTP headers say?

```
$ curl -I https://networkwalks.com
```

Header / item	Observed value
Status	HTTP/2 200
server	Apache
link	Advertises the REST API at `https://networkwalks.com/wp-json/` and a shortlink
set-cookie	`__wpdm_client` with `path=/; secure; HttpOnly`
permissions-policy	private-state-token-redemption and -issuance allowed for self, Google, gstatic, reCAPTCHA, Cloudflare challenges and hCaptcha
referrer-policy	`no-referrer-when-downgrade`
x-nginx-cache / x-endurance-cache-level	WordPress / 0 (caching layer headers)
date	Wed, 11 Nov 2026 05:52:33 GMT
Not seen in this capture	**Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options, Content-Security-Policy**

Together, `server: Apache`, `x-nginx-cache` and `x-endurance-cache-level` suggest a layered shared-hosting stack with a caching tier in front of Apache. That is my reading of the headers, not something the tool stated.

Attacker's perspective	Defender's takeaway
The Link header hands over the REST API entry point. The missing security headers leave room for clickjacking, MIME sniffing and protocol-downgrade tricks in a visitor's browser.	Add HSTS, X-Content-Type-Options and frame protection (Section 8 has a sample). The `Secure` and `HttpOnly` cookie flags and the HTTP/2 answer are good signs.

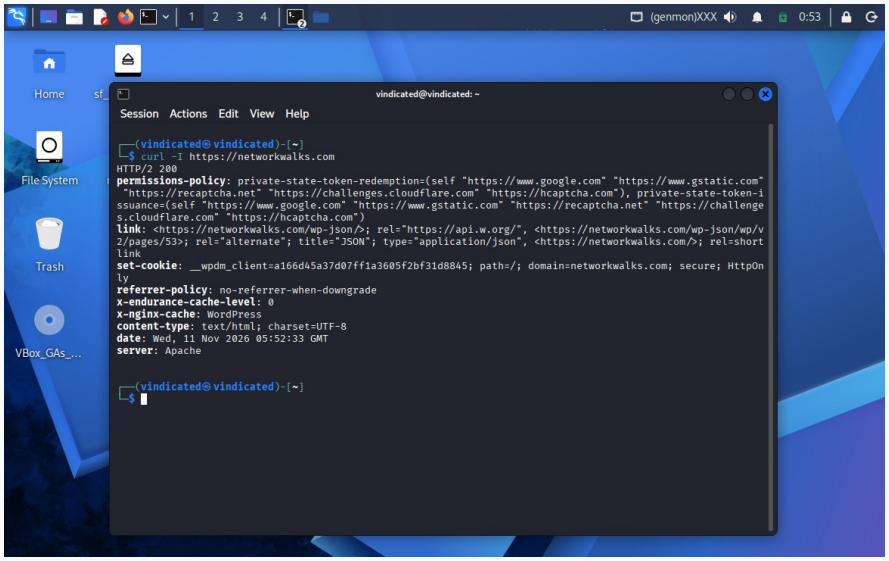


Figure 5. HTTP response headers returned by curl -I.

5.5 Wafw00f: is a firewall in front?

```
$ wafw00f networkwalks.com
```

Item	Observed value
Tool version	WAFW00F v2.4.2
Verdict	The site is behind **ModSecurity (SpiderLabs)** WAF
Requests needed	2

Attacker's perspective	Defender's takeaway
Knowing the WAF vendor lets an attacker choose evasion techniques aimed at that product. It also tells them the site is not completely unprotected.	A WAF is a real control and it is working. Because it was identified in only two requests, keep its rules up to date and do not treat it as a substitute for patching.

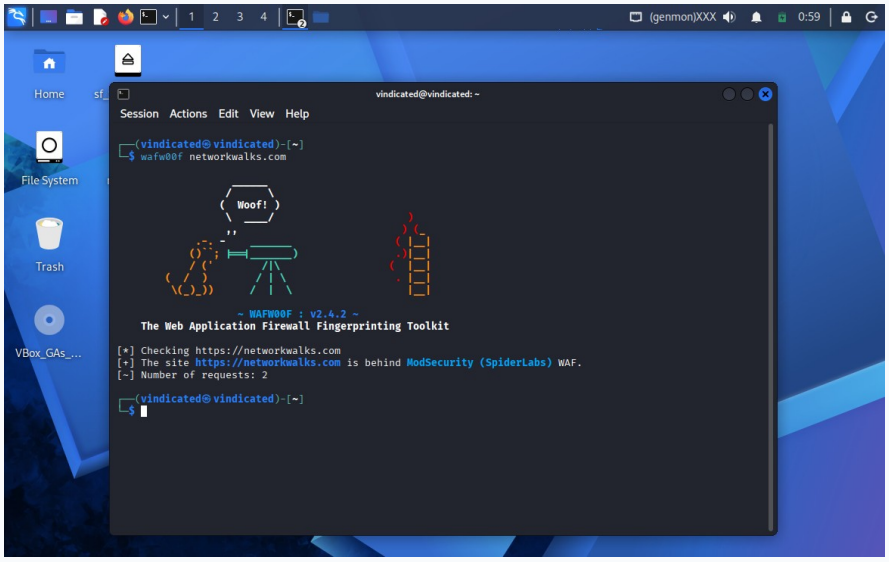


Figure 6. Wafw00f detecting ModSecurity (SpiderLabs).

5.6 DNSRecon: how is DNS and email set up?

```
$ dnsrecon -d networkwalks.com
```

Record	Observed value
SOA	`ns6135.hostgator.com` · 50.87.144.87
NS	`ns6135.hostgator.com` (50.87.144.87) and `ns6136.hostgator.com` (192.232.216.131)
BIND version	"9.16.23-RH" reported by both name servers
A	`networkwalks.com` → 192.232.216.135
MX	`mail.networkwalks.com` → 192.232.216.135
TXT (SPF)	`v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all`
TXT (other)	A Google site-verification record
SRV	`_autodiscover._tcp` → `cpanelemaildiscovery.cpanel.net` on port 443, across 184.94.203.x and 184.94.204.x (addresses ending .9, .11, .14, .15)
DNSSEC	Error: no answer for DNSSEC query (matches WHOIS: unsigned)

Reading the SPF record. It authorises the domain's own A and MX hosts, one IP address and the hosting provider's mail system (`websitewelcome.com`). It ends in `~all`, a soft fail: mail from other senders is marked suspicious but is not told to be rejected. The stricter ending is `-all`.

Attacker's perspective	Defender's takeaway
Name servers, mail host and cPanel autodiscover records reveal the hosting provider and its tooling, which makes a convincing phishing pretext. A soft-fail SPF record makes forged mail from the domain easier to get through, and a BIND version string helps profile the DNS servers.	Move SPF to `-all` after checking every legitimate sender, and add DKIM and DMARC. DNSSEC and the version banner belong to the DNS provider, so ask them. "RH" builds usually carry back-ported fixes, so the version number alone does not prove exposure.

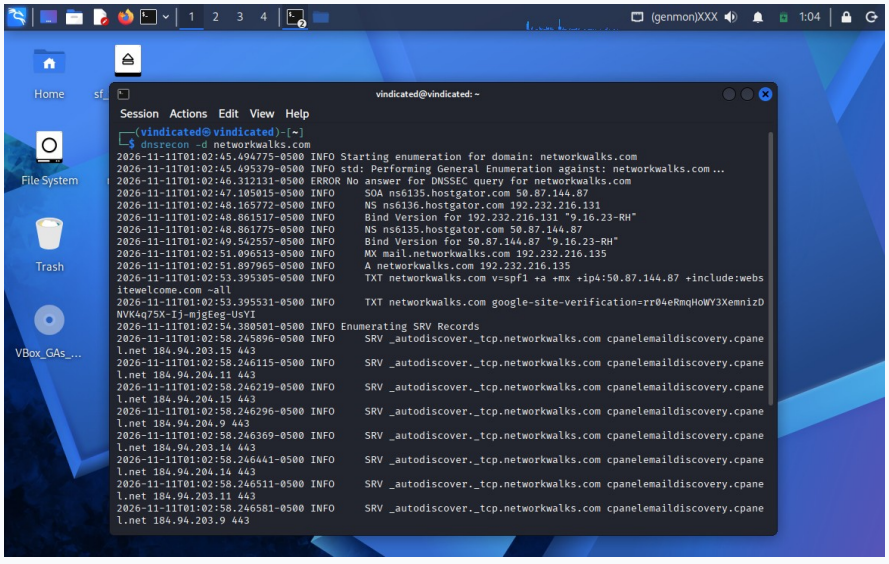


Figure 7. DNSRecon standard enumeration of networkwalks.com (top of output).

5.7 Putting it together

The infrastructure map below combines all six outputs. It shows one domain at one registrar, DNS served by HostGator name servers, a single IP address that answers for both the website and the mail host, and an application layer made of ModSecurity, Apache and WordPress.

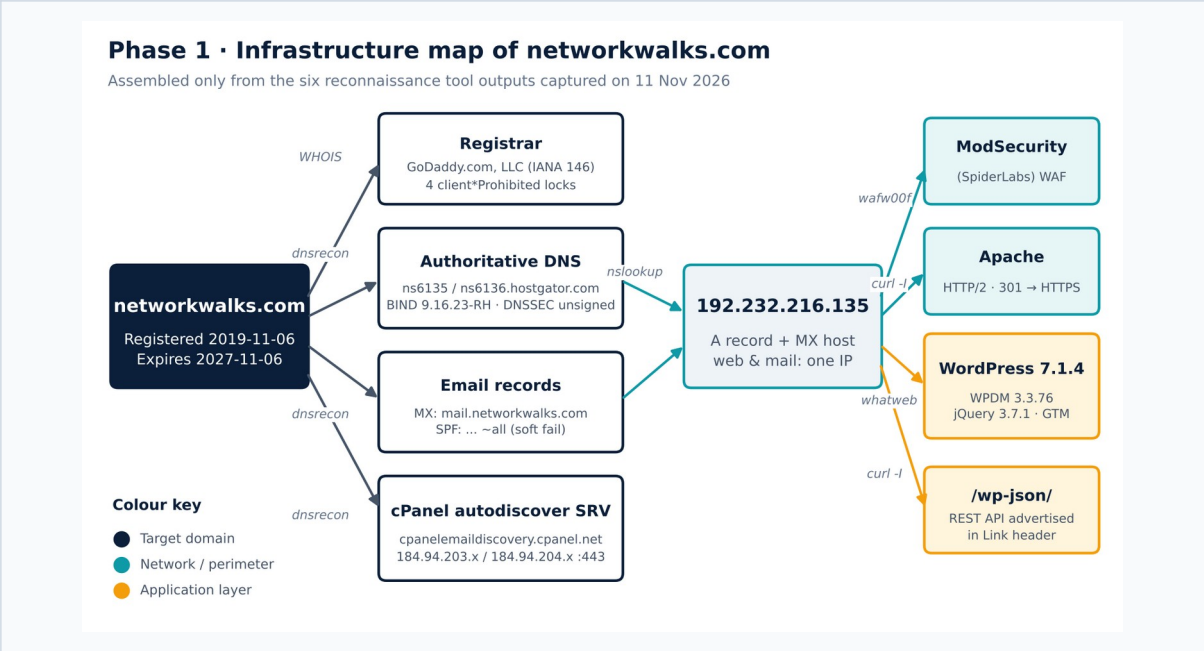


Figure 8. Infrastructure map of networkwalks.com built from the Phase 1 tool outputs.

6. Phase 2: Network Scanning with Zenmap

For the second activity I switched from a public target to my own network. The practical asks for three things: the local subnet, the list of live hosts with their IP and MAC addresses, and a topology view.

6.1 Scan set-up

Target	`192.168.18.1/24` (Nmap reads this as the whole /24 block, 256 addresses)
Profile	Ping scan
Command	`nmap -sn 192.168.18.1/24`
Nmap version / start	7.993 · 2026-11-11 12:08 (UTC+1)
Result	**8 hosts up** out of 256 addresses, scanned in 11.27 seconds

`-sn` tells Nmap to discover hosts without scanning ports. On a local Ethernet or Wi-Fi segment, Nmap does this with ARP requests, which is why a MAC address is shown for each device.

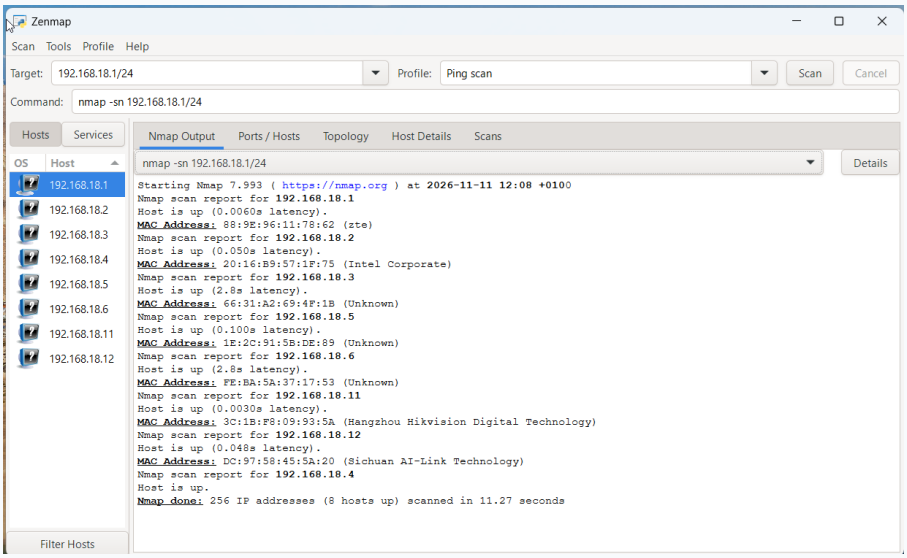


Figure 9. Zenmap Nmap Output tab for the ping scan of 192.168.18.0/24.

6.2 Host inventory

#	IP address	MAC address	Vendor (OUI lookup)	Latency	Observation
1	192.168.18.1	`88:9E:96:11:78:62`	ZTE	6 ms	Most likely the gateway / router (inferred from the .1 address and the vendor)
2	192.168.18.2	`20:16:B9:57:1F:75`	Intel Corporate	50 ms	Computer with an Intel network adapter
3	192.168.18.3	`66:31:A2:69:4F:1B`	Unknown	2.8 s	Locally administered MAC; very slow reply
4	192.168.18.4	not shown	n/a	not shown	“Host is up” only, with no MAC or latency: most likely the scanning PC itself

#	IP address	MAC address	Vendor (OUI lookup)	Latency	Observation
5	192.168.18.5	`1E:2C:91:5B:DE:89`	Unknown	100 ms	Locally administered MAC
6	192.168.18.6	`FE:BA:5A:37:17:53`	Unknown	2.8 s	Locally administered MAC; very slow reply
7	192.168.18.11	`3C:1B:F8:09:93:5A`	Hangzhou Hikvision Digital Technology	3 ms	**Camera / video-class vendor**
8	192.168.18.12	`DC:97:58:45:5A:20`	Sichuan AI-Link Technology	48 ms	**Looks like an IoT / Wi-Fi module vendor (unverified)**

6.3 Reading the MAC addresses

Three devices came back as “Unknown”. Their first MAC bytes (`66`, `1E`, `FE`) all have the **locally administered** bit switched on, which is the second-lowest bit of the first byte. Hardware makers never burn such addresses into a network card. Phones and tablets, however, often generate a random “private” Wi-Fi address for each network, and that address cannot be matched to a vendor. So the unknown devices are most likely personal mobile devices, although the scan alone cannot prove it.

First byte	Binary	Locally admin. bit	Reading
`88` (ZTE)	1000 1000	0	Factory-assigned address
`20` (Intel)	0010 0000	0	Factory-assigned address
`3C` (Hikvision)	0011 1100	0	Factory-assigned address
`DC` (AI-Link)	1101 1100	0	Factory-assigned address
`66`	0110 0110	**1**	**Randomised / locally set (.3)**
`1E`	0001 1110	**1**	**Randomised / locally set (.5)**
`FE`	1111 1110	**1**	**Randomised / locally set (.6)**

Latencies of 2.8 seconds on `.3` and `.6` are far above the 3 to 100 ms of the other hosts. Devices in Wi-Fi power-save mode answer slowly like this, which fits the phone theory. That is a guess, and the router’s client list would settle it.

6.4 Topology

Zenmap draws the scanner (`localhost`) in the centre with every discovered host around it. All eight hosts are green, which the legend defines as “fewer than 3 open ports”. In a ping scan no ports are checked, so green here means “not port-scanned” and says nothing about how safe a device is. The dashed lines mean there is no traceroute data, as expected for a single flat subnet.

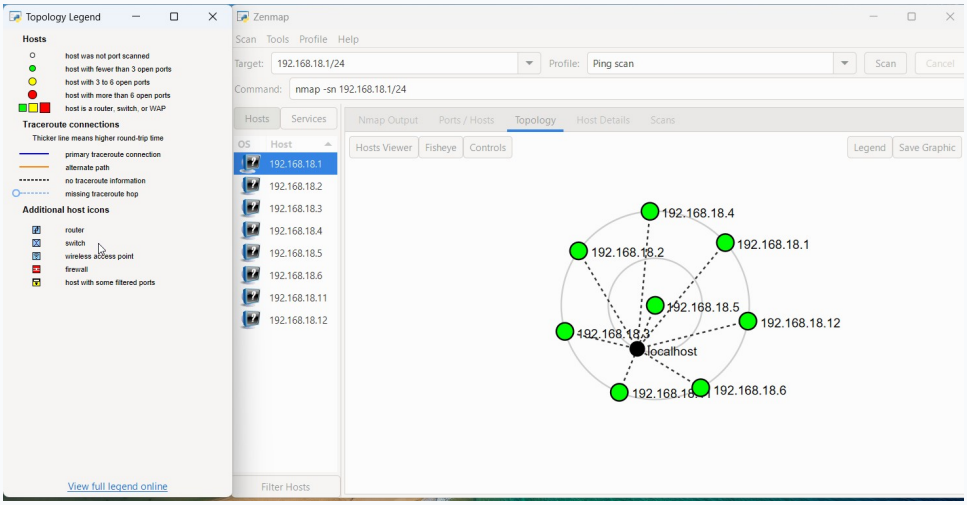


Figure 10. Zenmap Topology tab with the legend window open.

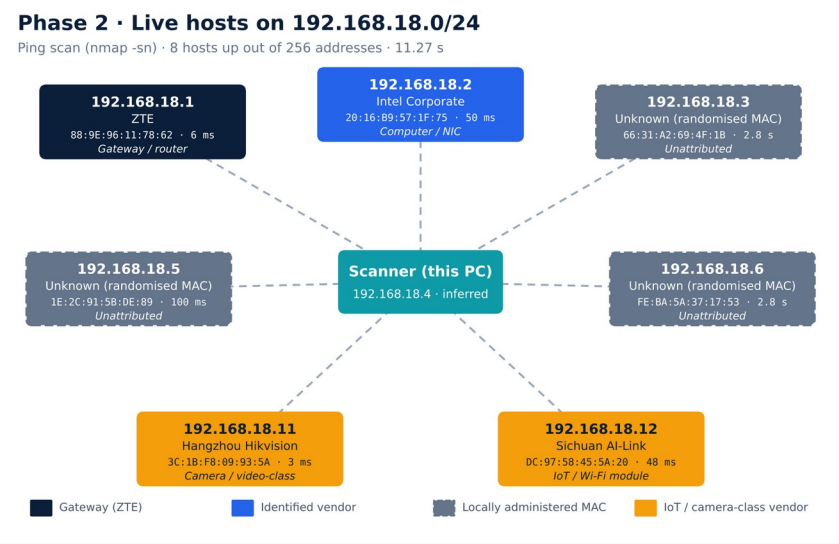


Figure 11. Device map of the same eight hosts, coloured by what the MAC lookup revealed.

6.5 What a ping scan cannot tell me

- It shows only devices that were awake and answering at 12:08. Anything switched off or asleep is missing.
- It reports no open ports, services, operating systems or software versions, so nothing here shows a device to be vulnerable.
- Vendor names come from the first three MAC bytes. They show who made the network chip, not necessarily what the device is.
- The router’s client list and a repeat scan are the next step for matching every device to an owner.

7. Risk Analysis & Findings Register

The risks below are observations from reconnaissance and host discovery. They are **not confirmed vulnerabilities**. A software version, an IP address or a DNS record does not make a system vulnerable by itself, and further authorised testing would be needed to prove any actual weakness. Ratings (scale in 7.2) describe how useful an exposure would be to an attacker.

7.1 Findings register

ID	Finding	Evidence	Potential impact	Severity
F-01	CMS and plugin versions fingerprinted	WhatWeb: WordPress 7.1.4, WPDM 3.3.76, jQuery 3.7.1	Lets an attacker match exact versions to public advisories. Plugins are a frequent entry point.	Medium
F-02	WordPress REST API advertised	curl -I: Link header points to `/wp-json/`	Easier endpoint discovery. Depending on configuration it can allow user enumeration.	Low
F-03	DNS software version disclosed	DNSRecon: BIND 9.16.23-RH on both name servers	Helps profile the DNS servers. The fix sits with the hosting provider.	Low
F-04	SPF ends in soft fail	TXT record `v=spf1 … ~all`	Forged mail from the domain is more likely to reach inboxes.	Low
F-05	DNSSEC not enabled	WHOIS: unsigned. DNSRecon: no answer to DNSSEC query	DNS answers cannot be cryptographically validated.	Low
F-06	Shared-hosting layout exposed	A and MX share one IP. cPanel autodiscover SRV. HostGator NS	Reveals the provider and tooling, and web plus mail share one host.	Low
F-07	Browser security headers not observed	curl -I: no HSTS, nosniff, X-Frame-Options or CSP	Weaker browser-side protection against clickjacking and downgrade.	Low
F-08	WAF vendor identifiable	wafw00f: ModSecurity (SpiderLabs) in 2 requests	Helps evasion planning. The WAF itself is a positive control.	Info
F-09	Public contact e-mail exposed	WhatWeb: `info@networkwalks.com`	Phishing and spam target. Expected on a business site.	Info
F-10	Camera and IoT-class devices on a flat subnet	Zenmap: .11 Hikvision, .12 Sichuan AI-Link	These devices often ship with weak defaults and slow firmware updates. On a flat network a compromised one can reach PCs.	Medium
F-11	Hosts with unattributable randomised MACs	Zenmap: .3, .5 and .6 use locally administered MACs	Vendor lookup cannot separate trusted from rogue devices, which weakens the asset inventory.	Low

7.2 Rating scale

Critical	Direct, easy path to full compromise. None observed.
High	Serious weakness that is likely to be abused. None observed.
Medium	Information or condition that meaningfully helps a real attack and should be fixed soon.
Low	Small weakness or disclosure that matters mainly in combination with others.
Info	Neutral or expected exposure, noted for completeness. May also be a positive control.

7.3 Controls that are working

Control	Evidence
HTTP to HTTPS redirect	WhatWeb: 301 Moved Permanently to the HTTPS site
Modern transport	curl: HTTP/2 200
Cookie hardening	curl: `__wpdm_client` is `Secure` and `HttpOnly`
Web application firewall	wafw00f: ModSecurity (SpiderLabs) active
Registrar locks	WHOIS: delete, renew, transfer and update prohibited
Browser policies present	curl: Permissions-Policy and Referrer-Policy headers returned
DNS redundancy	DNSRecon: two name servers on different IP addresses

No exploitation or vulnerability validation was done in either module. The work stayed at information gathering and host discovery.

8. Recommendations

Priorities: **P1** do first, **P2** do next, **P3** schedule when convenient. Effort is a rough estimate for a small team.

#	Recommendation	Fixes	Priority	Effort
R1	**Patch and monitor WordPress** Keep core, Download Manager and every plugin current. Enable automatic security updates, follow advisories and delete unused plugins and themes. Removing the generator tag is optional and never replaces patching.	F-01	**P1**	Low
R2	**Isolate cameras and IoT devices** Move the Hikvision and AI-Link devices to a separate VLAN or guest Wi-Fi. Change default credentials, update firmware and switch off UPnP and remote access that are not needed.	F-10	**P1**	Medium
R3	**Add browser security headers** Send HSTS, X-Content-Type-Options and frame protection (sample below). Test a Content-Security-Policy carefully because Google Tag Manager and the Download Manager need allowances.	F-07	**P2**	Low
R4	**Harden e-mail authentication** Verify all legitimate senders, then move SPF to `-all`. Publish DKIM and add DMARC, starting at `p=none` and moving to `quarantine` and `reject`.	F-04	**P2**	Medium
R5	**Limit REST API exposure** Keep the API for features the site needs, but require authentication on user-listing routes or use a hardening plugin.	F-02	**P2**	Low
R6	**Build a LAN asset inventory** Map every MAC and IP to an owner and device type using the router's client list. Reserve DHCP leases and investigate anything left unexplained.	F-11	**P2**	Low
R7	**Ask the DNS provider about DNSSEC and banners** DNS is hosted by HostGator, so DNSSEC and hiding the BIND version depend on the provider. Raise a ticket or consider a DNS host that supports DNSSEC.	F-03, F-05	**P3**	Medium
R8	**Keep the WAF tuned** Keep ModSecurity on, use a maintained rule set such as the OWASP Core Rule Set, and review its logs.	F-08	**P3**	Medium
R9	**Reduce harvestable contact details** Replace the plain e-mail address with a contact form or a monitored alias.	F-09	**P3**	Low
R10	**Repeat discovery on a schedule** Run `nmap -sn` monthly, compare runs with `ndiff` and keep the topology documented.	F-10, F-11	**P3**	Low

Sample Apache header configuration (R3)

```
# .htaccess or virtual host · requires mod_headers
Header always set Strict-Transport-Security "max-age=31536000"
Header always set X-Content-Type-Options "nosniff"
Header always set X-Frame-Options "SAMEORIGIN"
Header always set Referrer-Policy "strict-origin-when-cross-origin"
```

Roll HSTS out gradually. Add `includeSubDomains` or `preload` only after every subdomain is confirmed to work over HTTPS.

> **Always stay in scope**
>
> Run reconnaissance and scanning only against systems where written authorisation exists, and keep that evidence with the report.

9. Conclusion & Lessons Learned

In Week 2 of the Networkwalks Cybersecurity Program I carried out footprinting and network discovery from two angles: the outside view of a public website, and the inside view of my own network.

With six Kali tools I assembled a clear picture of networkwalks.com: who registered it, where its DNS lives, which IP serves it, what software runs it, and which firewall sits in front. With Zenmap I found eight live hosts on my network and learned which ones I could identify and which I could not.

What I learned

- **Tools confirm each other.** The address 192.232.216.135 showed up in Nslookup, WhatWeb and DNSRecon, which gave me confidence in the result.
- **Public data adds up fast.** None of the six tools needed an exploit, yet together they described the registrar, hosting, stack and mail set-up.
- **“Unknown” does not mean “rogue”.** The locally administered MAC bit explained why three devices had no vendor, and it saved me from a wrong conclusion.
- **Observations are not vulnerabilities.** A good report separates what was seen, what it could mean and what should be done, and says clearly what was not tested.
- **Scope comes first.** Every command ran only against a system I own or have written permission to test.

Next steps

- Compare WordPress 7.1.4 and Download Manager 3.3.76 with current security advisories.
- Check the DMARC and DKIM records, for example with `dig TXT _dmarc.networkwalks.com`.
- Match all eight local devices to owners using the router’s client list.
- Move on to Phases 3 to 5 with port and service enumeration, only against authorised targets.

— End of main report —

> **Author & project information**
>
> **Author:** Prince · Cybersecurity trainee
>
> **Programme:** Cybersecurity program at Networkwalks | **Week:** 02 | **Modules:** W2-PM1, W2-PM5
>
> **Repository:** github.com/vindicatedprince/networkwalks-week2-pentest-report

Appendix A: Command Log

Times are converted to UTC from what each tool printed. A dash means the screenshot shows no timestamp.

#	Tool	Command	Time (UTC)	Evidence
1	WHOIS	`whois networkwalks.com`	05:16 (database stamp)	Figure 2
2	WhatWeb	`whatweb networkwalks.com`	—	Figure 3
3	Nslookup	`nslookup networkwalks.com`	—	Figure 4
4	Curl	`curl -I https://networkwalks.com`	05:52 (Date header)	Figure 5
5	Wafw00f	`wafw00f networkwalks.com`	—	Figure 6
6	DNSRecon	`dnsrecon -d networkwalks.com`	06:02 (01:02 at UTC−5)	Figure 7
7	Zenmap / Nmap	`nmap -sn 192.168.18.1/24`	11:08 (12:08 at UTC+1)	Figures 9–10

Appendix B: Evidence Index

Figure	Description	File in repository
1	Findings by severity and area	`evidence/figures/fig_findings_summary.png`
2	WHOIS output	`evidence/01-whois.png`
3	WhatWeb output	`evidence/02-whatweb.png`
4	Nslookup output	`evidence/03-nslookup.png`
5	Curl header output	`evidence/04-curl-headers.png`
6	Wafw00f output	`evidence/05-wafw00f.png`
7	DNSRecon output	`evidence/06-dnsrecon.png`
8	Infrastructure map	`evidence/figures/fig_footprint_map.png`
9	Zenmap ping-scan output	`evidence/07-zenmap-ping-scan.png`
10	Zenmap topology	`evidence/08-zenmap-topology.png`
11	LAN device map	`evidence/figures/fig_lan_map.png`

Appendix C: MITRE ATT&CK Mapping

A learning aid that shows where each activity sits in the ATT&CK Reconnaissance tactic (TA0043).

Activity	ATT&CK technique
WHOIS lookup	T1596.002 · Search Open Technical Databases: WHOIS
Nslookup and DNSRecon	T1590.002 · Gather Victim Network Information: DNS T1596.001 · Search Open Technical Databases: DNS/Passive DNS
WhatWeb and curl -I	T1592.002 · Gather Victim Host Information: Software T1595 · Active Scanning
Wafw00f	T1590.006 · Gather Victim Network Information: Network Security Appliances
Zenmap ping sweep	T1595.001 · Active Scanning: Scanning IP Blocks T1590.004 · Gather Victim Network Information: Network Topology

Appendix D: Glossary & References

Term	Meaning
OSINT	Open-source intelligence: information gathered from public sources.
WAF	Web application firewall that filters malicious HTTP requests.
SPF / DKIM / DMARC	Three DNS-based mechanisms that help receivers decide whether mail really comes from a domain.
DNSSEC	Digital signatures on DNS data so that answers can be validated.
HSTS	A header that tells browsers to use HTTPS only for a site.
OUI	The first three MAC bytes, assigned to a manufacturer.
Locally administered MAC	An address set by software rather than the manufacturer, identified by a bit in the first byte.
Ping sweep	Host discovery that checks which addresses respond, without scanning ports.

References

- MITRE ATT&CK, Reconnaissance (TA0043) · https://attack.mitre.org/tactics/TA0043/
- Nmap Reference Guide · https://nmap.org/book/man.html
- OWASP Secure Headers Project · https://owasp.org/www-project-secure-headers/
- RFC 7208, Sender Policy Framework · https://datatracker.ietf.org/doc/html/rfc7208
- RFC 7489, DMARC · https://datatracker.ietf.org/doc/html/rfc7489
- RFC 6797, HTTP Strict Transport Security · https://datatracker.ietf.org/doc/html/rfc6797
- Penetration Testing Execution Standard · http://www.pentest-standard.org/
- WAFW00F · https://github.com/EnableSecurity/wafw00f
- DNSRecon · https://github.com/darkoperator/dnsrecon
- WhatWeb · https://github.com/urbanadventurer/WhatWeb